

From Cloud to Assembly Line: Modelling Cyberattack Paths in Automotive Manufacturing as Critical Infrastructure

Paper Number: XX-XXXX-XXXX

Henrique Hoffmann Stefanutti

Independent Researcher

Abstract

Vehicle cybersecurity research and regulation concentrate on the product: ISO/SAE 21434 and UN R155 govern the car, its ECUs and its back end. The factory that builds the car is governed by nothing comparable, yet it is the asset whose failure stops output, starves a continental supply chain and, in the most expensive cyber event recorded in the United Kingdom, cost an economy an estimated £1.9 billion. This paper treats the automotive plant, rather than the vehicle, as critical infrastructure, and asks a question that the vehicle-centric literature cannot answer: by which paths does an attacker actually reach the assembly line? We contribute (i) a curated corpus of 20 publicly reported incidents in automotive manufacturing between 2017 and 2025, each reconstructed as an asset-level path with an explicit confidence label; (ii) CAPM, a cross-plane attack-path model that spans corporate IT, the identity plane, cloud and SaaS, the industrial DMZ, MES/SCADA/PLC layers and the supplier interface, instantiated as a reference architecture of 12 IEC 62443 zones, 48 assets and 91 attack steps labelled with 43 MITRE ATT&CK Enterprise and ATT&CK for ICS techniques; (iii) a probabilistic analysis combining k -most-likely-path ranking with a Monte Carlo campaign simulation that quantifies annualised loss; and (iv) a control catalogue mapped to IEC 62443-3-3 and NIST CSF 2.0, evaluated by marginal value, necessity and cost-effectiveness. Four results follow. First, the path of least resistance to a production stoppage never touches a controller: the most likely route is $11.6\times$ more likely than the most likely route that reaches Purdue level 2 or below, and the corpus agrees: 55% of incidents caused an availability impact, while only 10% are reported to have interacted with equipment below level 3. Second, recovery capability dominates prevention in expected-loss terms: tested offline backups and a rehearsed degraded-production mode account for the two largest single-control reductions, while SaaS token governance and supplier assurance are the controls a mature programme can least afford to remove. Third, partial hardening displaces rather than removes risk: a supply-chain-and-cloud programme cuts espionage loss by 73% but raises ransomware loss by 26% by pushing a rational actor onto the availability objective. Fourth, measured against four baseline prioritisations on the same corpus, the model places the median observed incident at the 4.8th percentile of the routes to its consequence, where depth-into-OT and zone-crossing heuristics place it at the 95.9th and 98.9th; a ranking that ignores detection entirely, however, performs indistinguishably, so the containment term earns its place in the loss estimate and not in the ranking. The model, corpus, experiments and figures are released as a dependency-free open-source artefact.

Keywords: critical infrastructure, automotive manufacturing, attack graphs, operational technology, MITRE ATT&CK for ICS, IEC 62443, supply-chain security, risk quantification

Introduction

A modern vehicle assembly plant is a cyber-physical system of a peculiar kind. It is large, with tens of thousands of controlled devices across body, paint and final assembly, and it is tightly coupled: just-in-time and just-in-sequence logistics remove the inventory buffers that would otherwise absorb a disruption. It is also, increasingly, a *connected* system. Manufacturing execution systems (MES) exchange orders with enterprise resource planning (ERP) platforms; engineering workstations are managed from the same endpoint management infrastructure as office laptops; machine builders maintain robot cells from another continent; production analytics run in a public cloud tenant; suppliers receive call-offs through electronic data interchange (EDI) interfaces that are, functionally, a conduit into the plant's scheduling logic.

Regulation has not followed this shift. The automotive sector has invested a decade of standardisation effort in the security of the *product*: ISO/SAE 21434 defines cybersecurity engineering for road vehicles [1] and UN R155 makes a certified cybersecurity management system a condition of type approval [2]. Both stop at the factory gate. Conversely, the frameworks that do address industrial environments, IEC 62443 [3, 4] and NIST SP 800-82r3 [5], are sector-agnostic and organised around zone-and-conduit segmentation, a model whose implicit threat is an adversary descending the Purdue hierarchy [6] towards the process.

The empirical record does not fit that picture. Between 2017 and 2025, automotive production was halted repeatedly, at Renault-Nissan, Honda, Toyota, Bridgestone, Stellantis and Jaguar Land Rover, and in almost every case the reported cause was the loss of *information* systems, not the manipulation of controllers. Production stopped because the MES was encrypted, because ERP could not release parts, because a Tier-1 supplier could no longer transmit delivery data, or because the victim itself disconnected networks as a containment measure. The 2022 compromise of Kojima Industries, a Toyota Tier-1 supplier, stopped 28 lines across 14 Japanese plants and cost roughly 13,000 vehicles of output in a single day [7, 8], without any claim that a programmable logic controller (PLC) was touched. The 2025 attack on Jaguar Land Rover halted global production for approximately five weeks and was assessed by the UK Cyber Monitoring Centre as a Category 3 systemic event costing the British economy about £1.9 billion and affecting more than 5,000 organisations [9, 10].

If that is how plants actually fail, then risk models built around descent to level 0 are optimising the wrong variable. What the sector needs is an attack-path model that treats the corporate IT estate, the identity plane, the cloud tenant, the SaaS perimeter, the industrial DMZ, the operations layer and the supplier interface as a *single* graph whose terminal states are business consequences, and that can rank the routes through that graph by likelihood and expected loss.

Contributions

- **C1: an empirical corpus.** We curate 20 publicly reported incidents in automotive manufacturing (2017–2025), covering OEMs, Tier-1 suppliers, engineering-services providers and shared retail SaaS. Each record carries a reconstructed asset-level path and an explicit confidence label, so that the inevitable uncertainty of public reporting stays visible instead of being laundered (section 3).
- **C2: the CAPM model.** We define a cross-plane attack-path model with an explicit probability semantics, and instantiate it as a reference architecture for a vehicle assembly plant: 12 IEC 62443 zones spanning five planes, 48 assets, 91 attack steps labelled with 43 ATT&CK Enterprise and ATT&CK for ICS techniques, and five terminal consequences (section 4).
- **C3: path analysis, and a comparison.** We rank routes by exact k -most-likely-path enumeration, identify likelihood-weighted choke points, and measure the ranking against four baseline prioritisations that stand in for current practice, scoring all of them against the corpus (section 6).

- **C4: risk quantification.** A Monte Carlo campaign simulation with three actor profiles converts path structure into annualised loss expectancy, downtime distributions and time-to-consequence (section 6).
- **C5: control evaluation against standards.** A catalogue of 17 controls, each mapped to IEC 62443-3-3 system requirements and NIST CSF 2.0 subcategories, is evaluated by marginal value, necessity within a full programme, and cost-effectiveness, with a sensitivity and rank-stability analysis (sections 6 and 7).

All code, data, experiments and figures are released as a dependency-free artefact [11]; every number quoted in this paper is produced by a single reproducible pipeline.

Background and Related Work

Zones, conduits and the Purdue model

The Purdue Enterprise Reference Architecture [6] orders industrial assets into levels from the physical process (level 0) to enterprise IT (level 4/5), and is the backbone of the zone-and-conduit decomposition of IEC 62443-3-2 [3]. IEC 62443-3-3 [4] then assigns each zone a target security level (SL-T) realised by system requirements (SR). NIST SP 800-82r3 [5] gives compatible guidance, and the Industrial Control System Cyber Kill Chain [12] describes the two-stage structure, an IT intrusion stage followed by an ICS attack development stage, observed in Stuxnet [13], the Maroochy water breach [14], the Ukrainian grid attacks [15] and the historical record collected by the Idaho National Laboratory [16]. This literature is indispensable, but it is organised around the descent to the process. Our results suggest that for discrete manufacturing the dominant loss mechanism is a *lateral* business-process failure that never requires stage two.

Attack graphs and probabilistic security metrics

Attack graphs formalise the composition of individual steps into end-to-end compromise [17, 18], and logic-based generators such as MulVAL [19] made them tractable on real networks. Probabilistic metrics over attack graphs [20] attach success likelihoods to steps and aggregate them along paths; surveys [21, 22, 23] map the design space of attack/defence modelling. In industrial settings, attack trees and graphs have been applied to SCADA vulnerability assessment [24, 25], to grid exposure evaluation [26] and to combined safety–security analysis [27]; Cherdantseva et al. [28] review risk-assessment methods for SCADA and note the scarcity of empirically grounded parameterisation. Quantitative risk work in the Factor Analysis of Information Risk (FAIR) tradition [29, 30] supplies the loss-distribution machinery we adopt. What is missing, and what we supply, is a graph whose vertices span *all five planes* of a manufacturing enterprise and whose terminal states are production and business consequences, not host compromise.

ATT&CK Enterprise and ATT&CK for ICS

ATT&CK [31] and ATT&CK for ICS [32] provide the technique vocabulary used throughout this paper. A cross-plane path is *bilingual*: it begins in Enterprise techniques (T1566 Phishing, T1190 Exploit Public-Facing Application, T1078 Valid Accounts) and, if it descends, continues in ICS techniques (T0886 Remote Services, T0843 Program Download, T0831 Manipulation of Control). Labelling every edge with the matrix it belongs to lets us measure how much of the realistic risk mass is expressible in each vocabulary, and most of it turns out to be Enterprise.

Automotive cybersecurity: product versus plant

ISO/SAE 21434 [1] and UN R155 [2] regulate the vehicle’s cybersecurity engineering and management system. Sector supplier assurance schemes address information handling in the supply chain, and IEC 62443-2-4 [33] specifies requirements for service providers to industrial automation and control systems (IACS). Regulators have begun to treat manufacturing itself as in scope: the EU NIS 2 directive lists the manufacture of motor vehicles among the sectors it covers [34], and the United States classifies automobile manufacturing within the Critical Manufacturing Sector [35]. The scholarly literature has not kept pace: we are not aware of prior work that models the automotive *plant* as a cross-plane attack graph, calibrates it against the sector’s own incident record, and uses it to rank controls in the language of IEC 62443 and NIST CSF. The claim is bounded by the search described in the artefact, and by the literature reachable through it. Section 3 begins by establishing that record.

The Plant as Critical Infrastructure: An Incident Corpus, 2017–2025

Corpus construction

We assembled a corpus of publicly reported cybersecurity incidents whose victim is an automotive OEM, a component supplier, an engineering-services provider to the sector, or a shared platform on which vehicle production or distribution depends. An incident was included when (i) the victim or credible reporting identified an automotive nexus, (ii) at least one consequence was described in enough detail to be classified, and (iii) two independent sources or one first-party disclosure were available. We span the full consequence space (availability, confidentiality of engineering data, personal-data exposure) instead of restricting the corpus to production outages, because the model must be able to express the routes an actor *did not* take as well as the ones it did. The result is 20 incidents: two in 2017, two in 2020, five in 2022, four in 2023, three in 2024 and four in 2025 [36, 37, 38, 7, 8, 39, 40, 41, 42, 43, 44, 45, 46, 47, 9, 10, 48, 49]. The full record, including the source URLs for each incident and the date they were consulted, is published with the artefact [11].

Each record carries a reconstruction of the incident as a sequence of assets in the reference architecture of section 4, together with a confidence label: high when the sequence follows from the victim’s own disclosure; medium when several independent sources agree; low when the entry vector is reported but internal propagation is inferred; disputed when sources disagree on the entry vector; attempted when the campaign was interrupted before impact; and partial when the observed consequence lies partly outside the plant-centric scope of the model. The labels answer a structural problem of this research area: victims of manufacturing incidents rarely publish forensic detail, and a model that hides the resulting uncertainty behind confident-looking node sequences would be worse than one that exposes it. Table 1 lists the corpus.

Descriptive findings

Three properties of the corpus shape the rest of the paper.

Availability dominates. Eleven of twenty incidents had production stoppage as their primary consequence (55%, 95% Wilson CI 34–74%); five caused theft of engineering or corporate data and four exposed customer personal data. Twenty incidents support only wide intervals, so we report Wilson score intervals throughout: at this sample size the normal approximation is unusable near the extremes, and these proportions should be read for their direction, not their second digit.

The supply chain is a first-class attack surface. Eight of twenty incidents (40%, CI 22–61%) traversed the supply-chain plane, either because the victim *was* a supplier whose failure propagated to an OEM (Kojima/Toyota, Yanfeng/Stellantis, Sensata, MKS Instruments), or because a shared platform

Table 1: The incident corpus expressed in the reference model. “Pct.” is the percentile of the reconstructed path among all modelled paths that reach the same consequence (lower is more likely).

ID	Year	Victim	Impact	Conf.	$L(\pi)$	Pct.
INC-01	2017	Renault-Nissan	prod\{\}_stop	medium	0.00228	4.8
INC-02	2017	Honda	prod\{\}_stop	low	0.00228	4.8
INC-03	2020	Honda	prod\{\}_stop	low	0.00091	16.7
INC-04	2022	Toyota (via Kojima Industr	prod\{\}_stop	high	0.04678	0.2
INC-05	2022	Denso	ip	medium	0.06126	1.9
INC-06	2022	Bridgestone Americas	prod\{\}_stop	low	0.00079	17.8
INC-07	2022	Continental	ip	medium	0.01742	7.7
INC-08	2020	Tesla (Gigafactory Nevada)	prod\{\}_stop	attempted	0.00225	5.1
INC-09	2023	Toyota (T-Connect / G-Link	pii	high	0.02916	14.3
INC-10	2024	Volkswagen Group (Cariad)	pii	high	0.02916	14.3
INC-11	2024	CDK Global	prod\{\}_stop	partial	0.03150	0.7
INC-12	2024	Hyundai Motor Europe	ip	low	0.01512	9.6
INC-13	2023	Nissan Oceania	ip	medium	0.01475	11.5
INC-14	2023	Yanfeng (Stellantis suppli	prod\{\}_stop	medium	0.04678	0.2
INC-15	2025	Tata Technologies	ip	medium	0.06126	1.9
INC-16	2025	Sensata Technologies	prod\{\}_stop	medium	0.04678	0.2
INC-17	2025	Stellantis	pii	high	0.08400	4.8
INC-18	2025	Jaguar Land Rover	prod\{\}_stop	disputed	0.04078	0.4
INC-19	2022	Toyota (T-Connect)	pii	medium	0.01225	19.0
INC-20	2023	MKS Instruments	prod\{\}_stop	medium	0.04678	0.2

outside the OEM’s control was the point of failure (CDK Global, the SaaS platform behind the 2025 Stellantis disclosure).

Operational technology is rarely the target. Only two of the twenty incidents (10%, CI 3–30%) are reported to have interacted with equipment below Purdue level 3, and in both cases the interaction was self-propagating malware encrypting Windows-based production hosts, not a deliberate manipulation of control. No incident in the corpus involved a documented adversarial program download to a controller. Figure 1 shows the distribution of traversed planes.

Three case studies

Kojima Industries and Toyota (2022): coupling as an amplifier. Ransomware at a Tier-1 supplier of interior components encrypted the systems used to receive orders and confirm deliveries. Toyota, running just-in-time with minimal buffers, suspended 28 lines at 14 plants for a day, losing approximately 13,000 vehicles of output [7, 8]. The OEM’s own IT and OT estates were, by all public accounts, untouched. The transmission mechanism was not a network conduit but a *business* conduit: the flow of call-off and delivery data on which production sequencing depends. In model terms the entire path has three steps and never leaves level 4/5.

Jaguar Land Rover (2025): systemic loss from an IT-side event. Production stopped across the company’s plants from 31 August 2025, with a phased restart from early October. JLR has not disclosed the initial access vector; public reporting has variously pointed to the exploitation of Internet-facing enterprise software and to third-party credentials that were never revoked, and we therefore label the reconstruction disputed and encode the reported hypothesis while retaining the alternative as a distinct path in the model. What is not disputed is the consequence: the Cyber Monitoring Centre classified the event as a Category 3 systemic event with an estimated economic cost of £1.9 billion, affecting more than 5,000 organisations [9, 10]. Two features matter for modelling. First, the outage duration, roughly

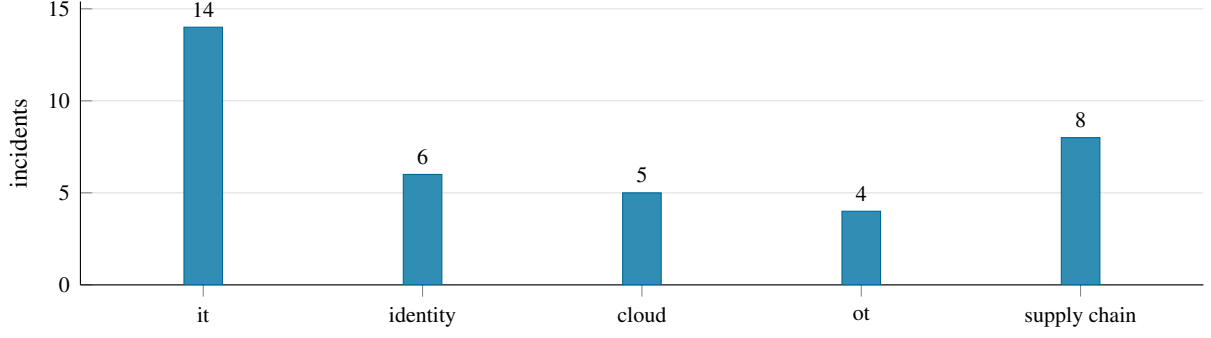


Figure 1: Planes traversed by the 20 corpus incidents (2017–2025). Only two incidents are reported to have interacted with equipment below Purdue level 3.

five weeks, is an order of magnitude longer than the 2017 worm-driven outages, which is what converts a plant incident into a national economic event. Second, the loss was borne well beyond the victim: a supplier ecosystem with no ability to influence JLR’s controls absorbed a large share of it.

Cariad, Toyota Connected and the SaaS perimeter (2022–2025): the cloud plane. Misconfigured cloud storage exposed data from approximately 800,000 electric vehicles at Volkswagen’s software subsidiary [44], a cloud misconfiguration exposed 2.15 million Toyota customers’ vehicle location records over a decade [43], an access key published in a public code repository exposed a further 296,000 [48], and in 2025 a third-party SaaS platform was the route to Stellantis customer data [47]. None of these stopped a line. They matter here because they are cheap, high-yield routes that compete for the same adversary effort as production disruption. As section 6 shows, that is why hardening them changes the *mix* of consequences a plant should expect.

The CAPM Model

Formal definition

A CAPM instance is a directed, labelled multigraph

$$G = (V, E, Z, \tau, p, \delta, c), \quad (1)$$

where V is a set of assets partitioned by Z into IEC 62443 zones, and $E \subseteq V \times V$ a set of atomic attack steps. V contains a distinguished entry vertex v_0 (the external actor) and a set $I \subset V$ of terminal *impact* vertices representing business consequences. Each edge e carries:

- $\tau(e)$, a MITRE ATT&CK technique (Enterprise or ICS);
- $p(e) \in (0, 1]$, the probability that the step succeeds given that the actor holds its source asset;
- $\delta(e) \in [0, 1)$, the probability that the step is detected *and contained* before the actor can build on it;
- $c(e) > 0$, the expected actor effort in hours.

A path $\pi = \langle e_1, \dots, e_n \rangle$ from v_0 to an impact has likelihood

$$L(\pi) = \prod_{i=1}^n p(e_i) (1 - \delta(e_i)), \quad (2)$$

the probability that every step succeeds and none is contained. Taking logarithms turns eq. (2) into the additive edge weight

$$w(e) = -\log(p(e)(1 - \delta(e))) \geq 0, \quad (3)$$

so the most likely path is a shortest path under w and the k most likely paths follow from Yen's algorithm. This is the standard log-transform of probabilistic attack-graph analysis [20]; it makes the ranking exact and avoids numerical underflow on long paths.

A control portfolio P acts on edges through two factors. A *mitigation* $m_P(e) \in [0, 1]$ removes a fraction of the step's success likelihood and a *detection uplift* $u_P(e) \in [0, 1]$ converts part of the remaining undetected mass into containment:

$$p_P(e) = p(e)(1 - m_P(e)), \quad (4)$$

$$\delta_P(e) = \delta(e) + (1 - \delta(e))u_P(e). \quad (5)$$

When several controls apply to the same step their effects compose multiplicatively on the residual, $1 - \prod_j(1 - m_j)$, which encodes diminishing returns from stacking overlapping controls.

Two structural metrics follow. For a ranked set of paths Π , the *criticality* of a vertex v is the share of aggregate likelihood mass traversing it,

$$\kappa(v) = \frac{\sum_{\pi \in \Pi, v \in \pi} L(\pi)}{\sum_{\pi \in \Pi} L(\pi)}, \quad (6)$$

and the same quantity computed over edges gives *conduit criticality*, which identifies the boundaries whose hardening removes the most aggregate risk. κ is the attack-graph analogue of flow betweenness, weighted by plausibility and not by count. The distinction matters: as section 6 shows, counting paths and weighting them by likelihood give opposite prioritisations.

Reference architecture

Figure 2 shows the instantiated plant. Beyond the classical Purdue stack we model two planes that Purdue drawings omit and one that they externalise:

- the **identity plane** (on-premises Active Directory, a cloud identity provider, federation trust, privileged access management, and dormant third-party credentials), which is where IT compromise becomes plant compromise;
- the **cloud plane** (tenant control plane, object storage and data lake, CI/CD pipeline, connected-vehicle back end) plus the third-party SaaS the enterprise does not operate;
- the **supply-chain plane** (Tier-1 IT estates, the EDI/JIT interface, machine-builder remote access, the OT software and firmware update channel, and removable media).

The instance comprises 12 zones, 48 assets and 91 attack steps drawn from 43 ATT&CK techniques, 70 steps labelled with Enterprise techniques and 21 with ICS techniques; 72 of the 91 steps cross a zone boundary and are therefore conduits in the IEC 62443 sense. Five terminal consequences are modelled: production stoppage, silent quality degradation, loss of a safety function, theft of engineering data, and customer personal-data breach.

Consequence and campaign model

Each impact $i \in I$ carries a consequence model: a triangular distribution over outage duration, a loss rate per hour of stopped production, and a triangular distribution of fixed response, forensic, regulatory

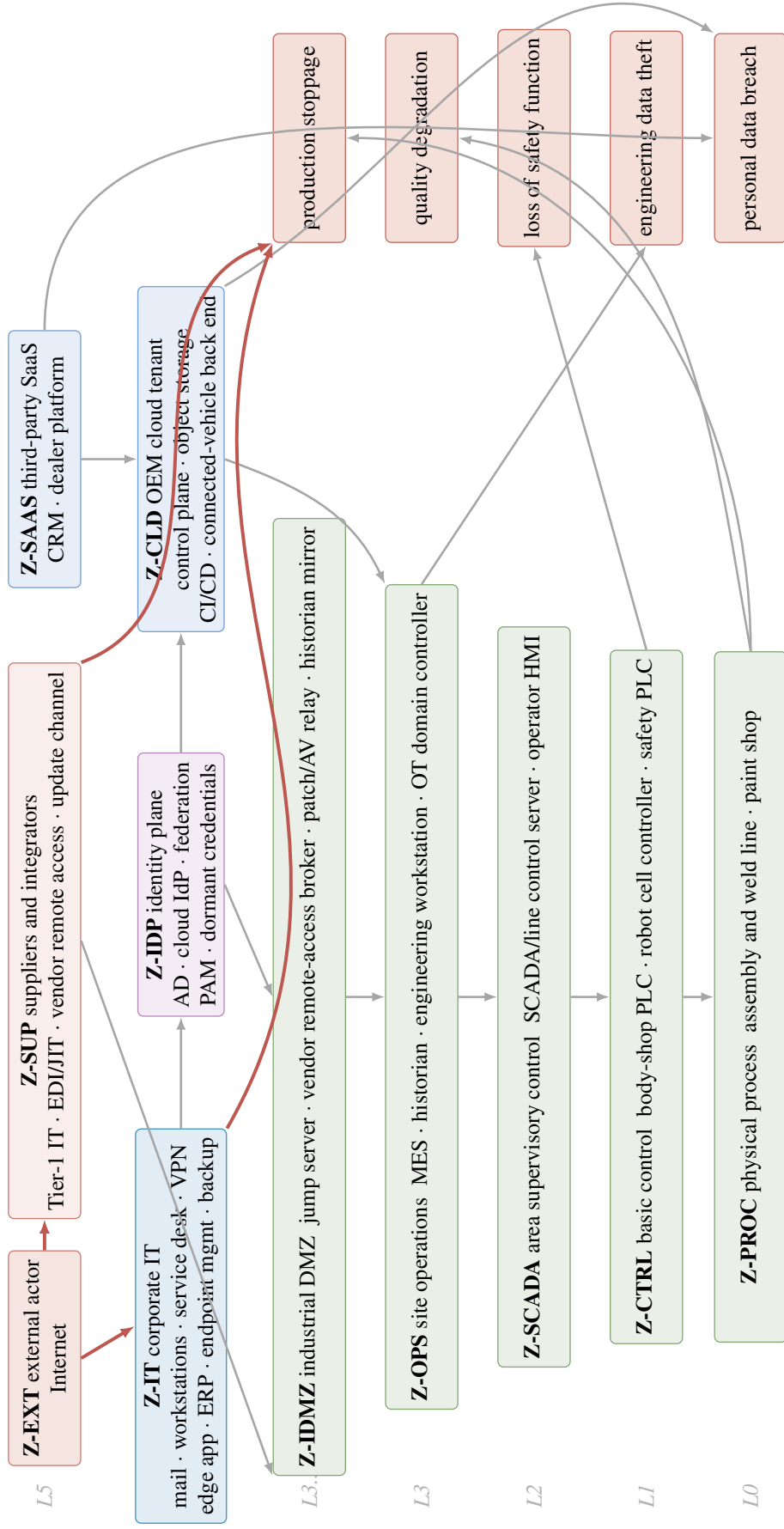


Figure 2: Reference architecture of the modelled vehicle assembly plant: 12 IEC 62443 zones across five planes, 48 assets and 91 attack steps. Dark arrows mark the two highest-likelihood routes to production stoppage found in section 6; both terminate in business and logistics systems without entering the control layers. Grey arrows show the remaining principal conduits.

and notification cost. Traversing a *recovery-inhibiting* asset (the backup infrastructure, the endpoint-management platform, the OT domain controller) multiplies the sampled outage, reflecting the empirical difference between a weekend outage and a five-week one. Consequence-side controls (tested offline backups, a rehearsed manual degraded mode) shorten it.

Path ranking answers where an actor is likely to go, but not how often a plant loses money, because a campaign is a sequential process under a time budget in which the defender may intervene at any step. We therefore simulate campaigns. An actor starts at v_0 with a budget (720 hours of hands-on-keyboard activity by default) and repeatedly selects, from all steps available out of the assets it holds, the one minimising

$$w(e) + d(\text{dst}(e)) + \varepsilon, \quad \varepsilon \sim \mathcal{N}(0, \sigma^2), \quad (7)$$

where $d(v)$ is the utility-weighted resistance from v to the actor’s objectives, the minimum over impacts of the residual path resistance minus the log-utility the actor assigns to that impact, and σ is a policy noise term representing imperfect adversary planning. The step consumes its effort, succeeds with probability $p_P(e)$ and is contained with probability $\delta_P(e)$; containment ends the campaign. We model three actor profiles by their utility vectors over consequences: *ransomware* (production stoppage dominant, data theft as double-extortion leverage), *espionage* (engineering data dominant) and *sabotage* (safety and quality dominant). Annualised loss expectancy (ALE) is $\text{ALE} = \lambda \cdot \mathbb{E}[\text{loss per campaign}]$ for a campaign frequency λ , with $\lambda = 1.5$ per plant-year in the baseline and swept in section 6.

Controls and standards mapping

The catalogue contains 17 controls, each characterised by its mitigation, detection uplift, recovery effect and a relative annualised cost index, and each mapped to the IEC 62443-3-3 [4] system requirements and NIST CSF 2.0 [50] subcategories it implements (table 2). The mapping is what makes the quantitative output actionable: a plant does not buy “a 0.55 mitigation factor”, it funds an SR 5.1 zone-boundary project or a PR.AA-03 phishing-resistant authentication programme. Five named scenarios are evaluated: S_1 identity-first, S_2 IEC 62443 zones and conduits, S_3 supply chain and cloud, S_4 detect and recover, and S_5 the full programme, against the baseline S_0 .

Parameterisation

Edge parameters are expert-elicited point estimates, and the supplementary material lists every one of them with the band it falls in, the controls that act on it, the corpus incidents that support it and the reason the step is modelled. They are anchored in four ways. Initial-access probabilities are ordered by the relative frequency of the corresponding entry vectors in the corpus and in public reporting on manufacturing intrusions. Lateral and descent probabilities reflect the technical preconditions of the step: whether it requires only valid credentials, an exploit, or physical presence. Detection probabilities encode the baseline monitoring maturity a mid-sized OEM plant can be assumed to possess *before* any catalogue control is deployed, which is why S_0 is described as a baseline and not as an unprotected configuration. Consequence parameters are anchored on reported outcomes: the one-day, 14-plant Toyota stoppage at one end of the duration distribution and the five-week Jaguar Land Rover outage at the other. The loss rate per stopped hour and the fixed response costs are the coarsest parameters in the model, and the first a plant should replace with its own figures.

We make no claim that these point estimates are the true parameters of any specific plant. The right response to elicited parameters is to test what they support: section 6 therefore reports how conclusions move under systematic perturbation, and treats any finding that does not survive that perturbation as unsupported.

Experimental Design

Six experiments run over the same graph instance. **E1** enumerates every loop-free path of at most twelve steps from the entry vertex to a consequence, ranks paths by eq. (2), and measures the depth each path reaches in the Purdue hierarchy. **E2** reconciles the corpus with the model: whether each reconstructed incident is a path of the model, where that path falls in the model’s own ranking, and how the model behaves under an ablation described below. **E3** computes vertex and conduit criticality. **E4** runs the campaign simulation for three actor profiles across the six control scenarios. **E5** evaluates each control three ways: its *marginal* value when deployed alone on the baseline, its *necessity* measured as the loss that returns when it is withdrawn from the full programme, and its cost-effectiveness; it then builds a greedy portfolio by repeatedly adding the control with the best risk reduction per unit cost. **E6** tests robustness: the stability of the path ranking under multiplicative log-normal perturbation of every p and δ ($\sigma = 0.35$, 200 replicates), one-at-a-time sweeps of detection efficacy, campaign frequency and actor budget, and the stability of the control ranking across twelve perturbed graphs.

E7 measures the model against the alternatives. It ranks the same path set with four baseline heuristics that stand in for current practice, and scores every ranking, CAPM included, against the same ground truth: the percentile at which the corpus incidents fall among the paths that reach the same consequence. The baselines are B1, fewest steps, the classical attack-graph proxy; B2, exploitability only, which multiplies step success probabilities and ignores detection and containment, as vulnerability scoring does; B3, deepest OT reach, the implicit ranking of zone-centric practice; and B4, most zone boundaries crossed, the segmentation-centric reflex. Rankings are compared with an exact two-sided Wilcoxon signed-rank test on the paired percentiles and with Kendall’s τ_b over the full path set. A consequence-magnitude baseline is absent by design: because paths are scored within the set reaching the same consequence, such a ranking is constant inside every comparison set and collapses onto its tie-breaker.

Monte Carlo experiments use 20,000 campaigns per configuration with fixed seeds; the full pipeline runs in about nine minutes on a single core of a commodity machine and requires only a CPython 3.9+ interpreter. Because the corpus informed the construction of the graph, plain coverage would be a consistency check and not a validation. **E2** therefore adds a leave-one-out ablation: for each incident, every edge whose *only* supporting evidence is that incident is deleted and the incident is re-tested against the reduced model. A path that survives is expressed by structure that generalises across cases, not by steps fitted to a single one.

Results

F1: the path of least resistance bypasses the control layers

The reference architecture admits 681 distinct attack paths of at most twelve steps: 455 reach production stoppage, 118 quality degradation, 52 engineering data theft, 35 a safety consequence and 21 a personal-data breach. Counted naively, the plant looks like a classical OT problem: 379 of the 455 production paths (83%) pass through Purdue level 2 or below.

Figure 3 shows what happens when those paths are weighted by how likely they are. Paths that never descend below level 4 are 8.5% of the graph (58 of 681) and carry 68.7% of the aggregate likelihood; the 532 paths that reach level 2 or below are 78% of the graph and carry 17.5%. Counting paths and weighting them by plausibility order the plant’s problems in opposite directions.

Weighting by likelihood inverts that conclusion. Figure 4 and table 3 give the ten most likely routes to production stoppage. The most likely path has three steps and a likelihood of 0.047: *external actor* $\rightarrow$ *Tier-1 supplier IT* $\rightarrow$ *EDI/JIT interface* $\rightarrow$ *production stoppage*. The second, at 0.041, is *external actor* $\rightarrow$ *Internet-facing enterprise application* $\rightarrow$ *ERP* $\rightarrow$ *production stoppage*. The most likely path that actually reaches level 2 or below has a likelihood of 0.0040. The highest-likelihood route to a stopped

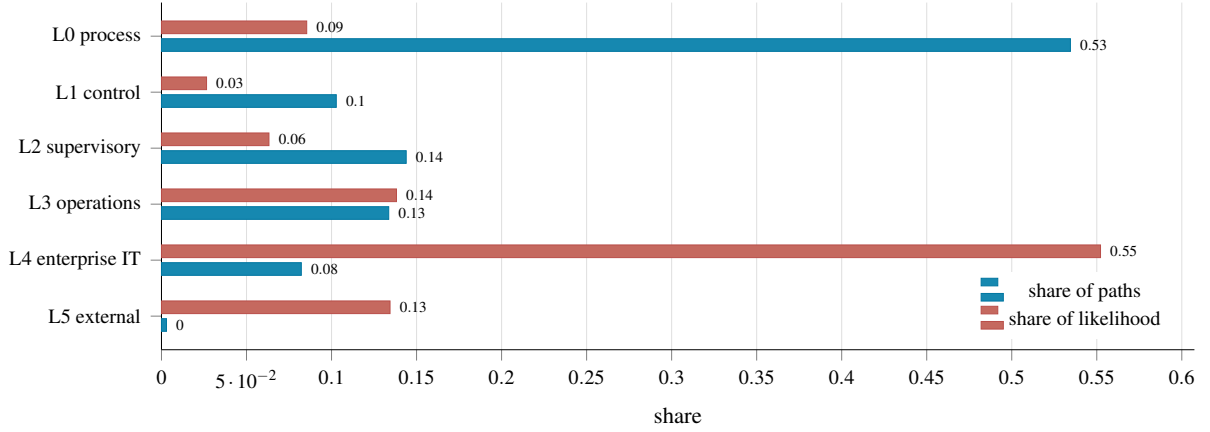


Figure 3: Where the risk lives. For each Purdue level, the share of modelled paths that reach it as their deepest point (left bars) against the share of aggregate path likelihood those paths carry (right bars). Most paths go too deep; most of the plausible risk does not.

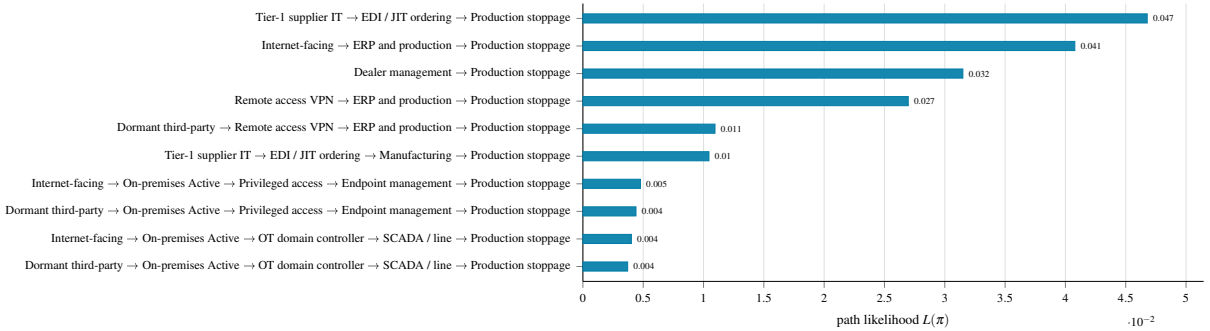


Figure 4: Ten most likely attack paths to production stoppage in the baseline configuration S_0 . The highest-likelihood routes terminate in business and logistics systems, not in controllers.

line is $11.6\times$ more likely than the highest-likelihood route that touches supervisory control or below.

The technique profile follows (fig. 5). Ranked by share of aggregate path likelihood, the leading techniques are T1567.002 (exfiltration to cloud storage, 0.35), T1210 (exploitation of remote services, 0.25), T1078 (valid accounts, 0.23), T1190 (exploit public-facing application, 0.22), T1133 (external remote services, 0.21) and T1486 (data encrypted for impact, 0.17). The first ICS technique appears far down the ranking. Of the 91 modelled steps, 21 are ICS techniques, yet they carry a small share of the plausible risk mass: ATT&CK for ICS remains essential for describing what an actor *could* do to the process, but ATT&CK Enterprise describes what stops the line.

F2: the model agrees with the record

All 20 corpus incidents are expressible as paths of the reference model. More informative is where those paths fall in the model’s own ranking: the median reconstructed incident sits at the 4.8th percentile of all modelled paths reaching the same consequence, and all 20 fall within the top quartile. The routes that actually occurred are the routes the model considers most likely, which is the behaviour a usable prioritisation instrument must exhibit.

Under the leave-one-out ablation, 13 of 20 incidents (65%) remain expressible after deleting every step that exists solely on their own evidence, rising to 75% when only internal propagation steps are ablated and initial access is retained. The failures are informative: they are almost entirely *initial-access* steps: the drive-by download behind the Continental intrusion, the insider recruitment attempted at

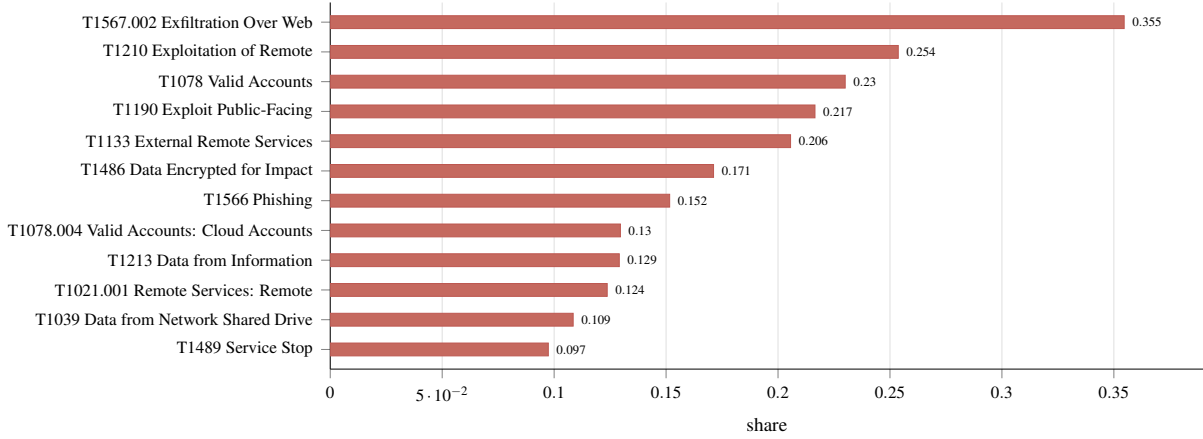


Figure 5: MITRE ATT&CK techniques ranked by the share of aggregate path likelihood that traverses them (Enterprise and ICS matrices combined).

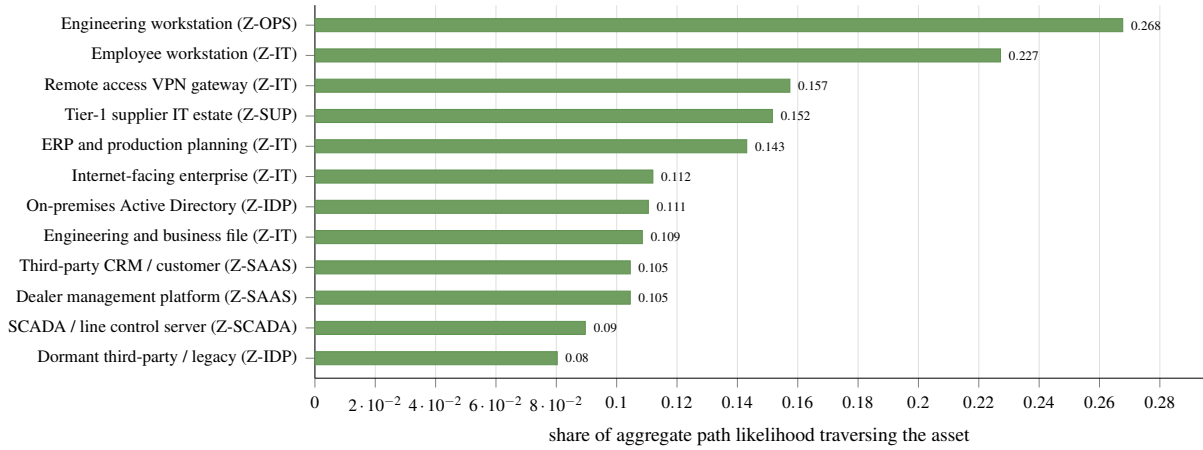


Figure 6: Likelihood-weighted choke points of the reference architecture.

Tesla, the dealer-platform compromise at CDK, the SaaS token abuse behind the Stellantis disclosure, the exposed cloud secret in a public repository. Entry vectors in this sector are idiosyncratic and each new campaign tends to introduce one; what generalises is what happens afterwards. That asymmetry has a direct defensive reading, taken up in section 7.

F3: the choke points are business systems

Figure 6 ranks assets by the share of aggregate path likelihood traversing them. Excluding the consequence vertices themselves, the leading choke points are the engineering workstation (0.27), the employee workstation (0.23), the remote-access VPN gateway (0.16), the Tier-1 supplier IT estate (0.15) and the ERP core (0.14). At the conduit level the highest-criticality transitions are *actor* → *Tier-1 supplier* via T1566 (0.15), *actor* → *Internet-facing application* via T1190 (0.11) and *actor* → *VPN* via T1133 (0.11).

The engineering workstation deserves emphasis. It is the one asset that appears at high criticality in *both* regimes: it is the hinge of the descent into control (every program-download path passes through it) and it is reachable from the corporate estate through endpoint management, flat-network exploitation, vendor remote access, removable media and insider access. In IEC 62443 terms it is a level 3 asset routinely administered from level 4, a zone whose SL-T is undermined by the conduits its administrators require.



Figure 7: Consequence mix per campaign under each control scenario, big-game ransomware profile. S_3 removes the cheap data-theft outcomes and the production-stoppage probability rises: the displacement effect of section VI.D made visible.

F4: scenario risk and the displacement effect

Figure 8 and table 5 report campaign outcomes. In the baseline against the ransomware profile, 9.8% of campaigns reach a consequence, 7.7% cause a production stoppage, and 90.2% are contained before any consequence. Mean loss is \$31.7M per campaign and \$323M conditional on impact, with a 95th percentile of \$733M; mean time from first action to first consequence is 35 hours. At $\lambda = 1.5$ campaigns per plant-year this is an annualised loss expectancy (ALE) of \$47.6M. Every monetary figure in this section is a property of the reference architecture under the parameters stated above, not a forecast for any real manufacturer; the figures are meant to be read comparatively, between scenarios and between controls, and the sweep over λ in fig. 11 shows how much of the absolute value rests on an assumption about targeting.

Two scenario results need stating exactly.

Detection and recovery dominate. S_4 (endpoint detection with monitored response, immutable and exercised backups, attack-surface management and operational resilience) reduces ALE by 64.6% to \$16.9M. The full programme S_5 reduces it by 92.9% to \$3.4M. By contrast, S_1 (identity-first) and S_2 (IEC 62443 zones and conduits) each move baseline ALE by about 1%. Identity hardening and segmentation are what make the *OT* paths expensive, so the result says nothing against them. It says where the expected loss currently sits.

Partial hardening displaces risk. S_3 (supply chain and cloud) cuts espionage-profile ALE from \$22.0M to \$5.9M, a 73% reduction, while *raising* ransomware-profile ALE by 26.3%, from \$47.6M to \$60.1M. The mechanism is visible in the simulation traces: in the baseline, a utility-aware actor frequently detours to cheap data-theft objectives and is often contained during those detours; removing the cheap objectives concentrates the campaign on the most damaging one.

Figure 7 shows the mechanism directly. Moving from S_0 to S_3 drives the probability that a campaign ends in a customer-data breach from 0.019 to 0.0003 and in engineering-data theft from 0.0050 to 0.0008, while the probability of a production stoppage rises from 0.077 to 0.103. The budget the actor no longer spends on cheap objectives is spent on the expensive one.

Risk displacement of this kind is invisible to control assessments that score each objective independently, and it argues for sequencing a programme so that availability protection does not lag confidentiality protection.

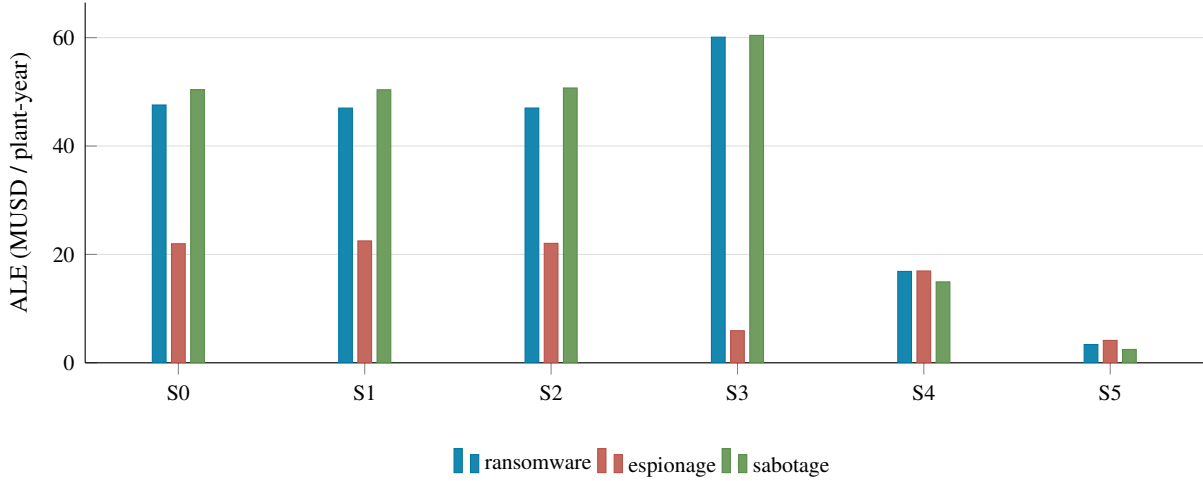


Figure 8: Annualised loss expectancy per control scenario and actor profile. Scenario S_3 lowers espionage risk sharply while *increasing* ransomware risk: hardening the cheap data-theft routes displaces a rational actor onto the availability objective.

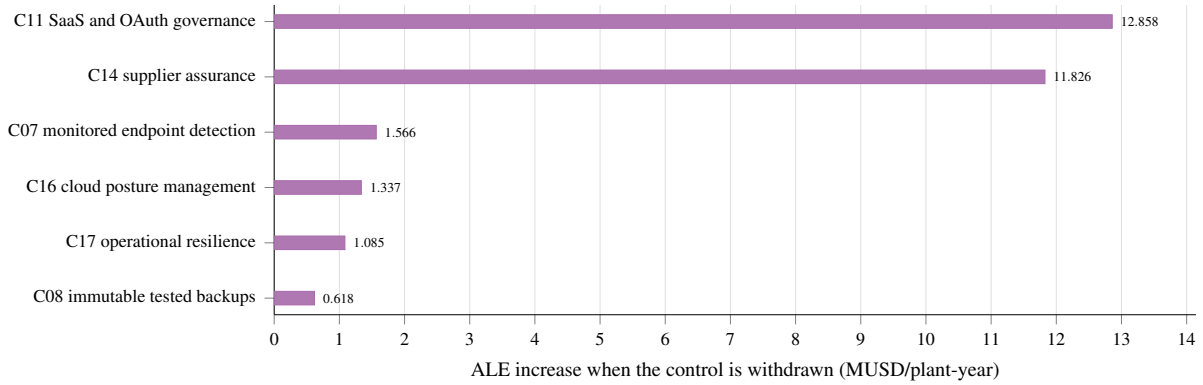


Figure 9: Necessity of each control inside the full programme S_5 : the annualised loss that returns when that control alone is withdrawn.

F5: which controls matter, and in what sense

Deployed alone on the baseline, only four controls produce a material ALE reduction against the ransomware profile: operational resilience C_{17} (\$20.2M), immutable and exercised backups C_{08} (\$18.3M), attack-surface management C_{10} (\$5.5M) and monitored endpoint detection C_{07} (\$4.9M). Every other control, taken alone, is worth close to nothing. Each one still works on the steps it covers; the graph simply offers redundant routes around it. The best single-control reductions of the *leading path likelihood* are supplier assurance C_{14} (−12.8%) and operational resilience C_{17} (−10.0%); a control can bend the top route substantially and still barely move expected loss.

Necessity tells the complementary story (fig. 9). Withdrawing a single control from the full programme S_5 costs most for SaaS and OAuth token governance C_{11} (+\$12.9M) and supplier security assurance C_{14} (+\$11.8M), followed by monitored detection C_{07} (+\$1.6M) and cloud posture management C_{16} (+\$1.3M). The controls that are worthless alone are the ones a mature programme cannot remove: they are the walls that close the routes the other controls push the actor towards. Marginal analysis alone, the standard way security investments are justified, systematically undervalues them.

Greedy selection by risk reduction per unit cost yields, for the ransomware profile, the sequence C_{08} (backups), C_{17} (operational resilience), C_{11} (SaaS token governance), C_{10} (attack-surface management), C_{14} (supplier assurance), C_{02} (conditional access), taking ALE from \$47.6M to \$5.5M for 31 of the

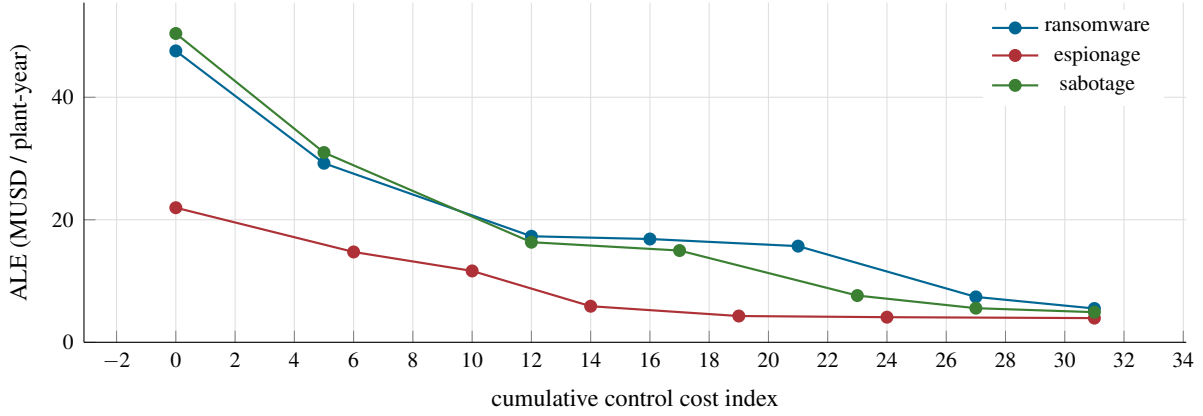


Figure 10: Efficient frontier obtained by greedy selection on marginal risk reduction per unit cost, for each actor profile.

91 units of cost index that the full catalogue would consume, an 88% reduction, which is 95% of the reduction achieved by the complete 17-control programme for roughly a third of its cost (fig. 10, table 6). The ordering is profile-dependent: against the sabotage profile the OT-side controls that barely register for ransomware enter the frontier much earlier, which is the quantitative form of the observation that a plant's control priorities depend on who is expected to attack it.

F6: what survives perturbation

Under multiplicative log-normal perturbation of every probability parameter ($\sigma = 0.35$, 200 replicates), the top-ten ranking of production-stoppage paths retains on average 65.7% of its members, and the single most likely path remains first in 36% of replicates. The *qualitative* finding is far more stable than the ordering: in every replicate the leading paths remain short, IT- and supply-chain-side routes, because the deep OT routes are longer and multiplicative penalties compound with length. Conclusions about which *class* of route dominates are supported; claims about the precise ordering within the top ten are not, and we do not make them.

One-at-a-time sweeps (fig. 11) identify detection efficacy as the dominant parameter: halving every δ raises baseline ALE from \$47.6M to \$176.8M, a factor of 3.7, while increasing it by 50% lowers ALE to \$14.2M. ALE is linear in campaign frequency by construction, so the range \$15.9M–\$126.8M across $\lambda \in [0.5, 4.0]$ measures the cost of uncertainty about targeting, not about the plant. Across twelve perturbed graphs, the control ranking by cost-effectiveness is led consistently by C_{08} (mean rank 2.3), C_{17} (3.3) and C_{10} (3.8); supplier assurance C_{14} and SaaS governance C_{11} have high variance (best rank 1, worst rank 17), reflecting genuine sensitivity to how exposed a given plant's supplier and SaaS interfaces are.

F7: against the prioritisations a plant uses today

Table 4 and fig. 12 score CAPM and the four baselines on the same ground truth. CAPM places the median corpus incident at the 4.8th percentile of the paths reaching its consequence, with all 20 incidents inside the top quartile and 14 inside the top decile.

The two heuristics that encode conventional industrial intuition fail badly. Ranking by depth into the Purdue hierarchy (B3) puts the median observed incident at the 95.9th percentile, near the *bottom* of its own list, with 4 of 20 incidents in the top quartile and Kendall's $\tau_b = -0.08$ against CAPM. Ranking by the number of zone boundaries crossed (B4) is worse still: median percentile 98.9, not a single incident in the top quartile, and a rank-biserial effect of -1.00 , meaning CAPM ranked every one of the twenty

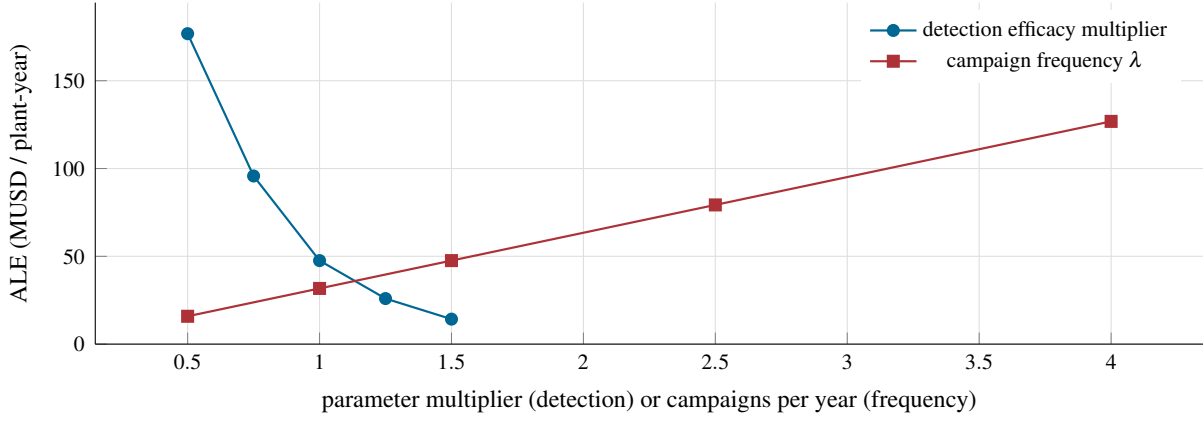


Figure 11: One-at-a-time sensitivity of the annualised loss expectancy. Halving detection efficacy multiplies the baseline ALE by 3.7; the response to campaign frequency is linear by construction.

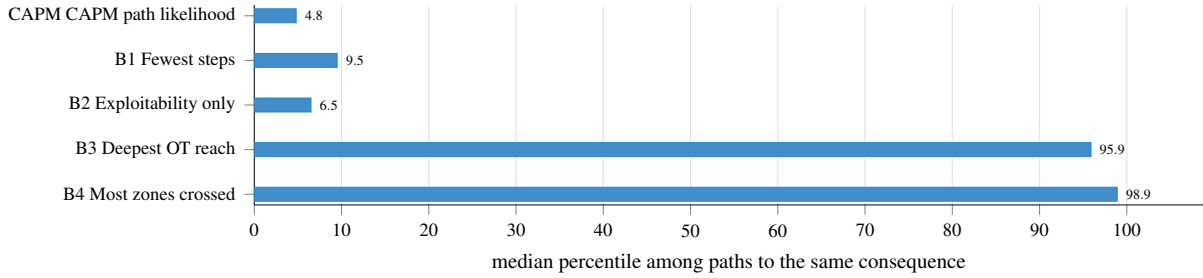


Figure 12: Median percentile of the corpus incidents under each prioritisation (lower is better). The segmentation- and depth-centric heuristics rank the routes that actually occurred near the bottom of their lists.

incidents higher. Both differences are significant at $p < 10^{-4}$. A plant that prioritises the paths which go deepest, or which cross the most zones, is prioritising almost exactly the routes that the sector’s incidents have not taken.

Two results are more sobering for the model. Fewest-steps ranking (B1) is a weak but real competitor: median percentile 9.5, 18 of 20 incidents in the top quartile, and CAPM beats it significantly ($p = 0.010$) but not dramatically: much of CAPM’s advantage over B1 comes from preferring short paths, which B1 does by construction. And exploitability-only ranking (B2), which discards the containment term δ entirely, is *statistically indistinguishable* from full CAPM on this criterion (median 6.5 versus 4.8; $p = 0.99$; rank-biserial effect +0.02). We report it because it stands: on the evidence available, modelling detection and containment does not measurably improve the *ranking* of routes. Its value lies elsewhere in the model, and is large. Figure 11 shows detection efficacy to be the single most influential parameter of the loss estimate, moving annualised loss by a factor of 3.7 across the swept range. The defensible claim is therefore narrower than one might wish: the containment term earns its place in the risk quantification, not in the path ranking.

Discussion

The conduits that matter are business processes

IEC 62443 asks an organisation to define zones and the conduits between them, and practitioners instinctively read “conduit” as “network path”. The results argue for a broader reading. The single most likely route to a stopped line in our model, and the route taken in the most consequential supply-chain

incident in the corpus, is a *data-flow* conduit: the stream of call-offs, sequencing instructions and delivery confirmations between a supplier and the plant. It carries no control traffic, crosses no OT firewall and is invisible to an asset-centric zone model, yet its interruption stops production as effectively as a controller failure. The same is true of the ERP–MES coupling. A 62443 risk assessment that enumerates only technical conduits will assign these flows no SL-T and no monitoring requirement.

The practical recommendation is to extend the zone-and-conduit exercise with a *production-dependency* conduit inventory: for each business data flow on which sequencing, parts availability or dispatch depends, record its source zone, its owner (often a third party), the maximum tolerable interruption, and the manual fallback. In our model this is exactly what control C_{17} represents, and it is the second-best single investment available.

Recovery is a security control

The two largest single-control reductions in expected loss are tested offline backups and a rehearsed degraded-production mode, both of which act on the consequence instead of the likelihood. This is not an artefact of our parameters but a structural property of a tightly coupled system with a heavy-tailed outage distribution: when mean loss is dominated by the tail, shortening the tail beats shaving the probability of entering it. The empirical record points the same way. The 2017 worm outages lasted a weekend; the 2025 JLR outage lasted five weeks and became a national economic event [9]. The difference between those two outcomes is a recovery difference, not a prevention difference.

A corollary for governance: recovery capability should be audited with the same rigour as preventive controls, which in practice means evidence of restoration exercises that include OT artefacts (controller projects, HMI images, MES databases, recipe and parameter sets) and evidence that a plant can run in a degraded mode without its MES for a defined period.

Prioritisation is adversary-dependent, and partial programmes displace risk

The greedy frontier differs across actor profiles, and S_3 lowers espionage loss while raising ransomware loss. Both findings caution against a single ranked control list presented as universally optimal. A plant that models only one adversary will systematically misprice the controls that matter to another, and a programme that hardens confidentiality-oriented routes first can increase availability risk in the interim. The defensible position is to sequence investments so that consequence-side controls, which are objective-agnostic because they act after the actor has succeeded, are in place before selectively hardening one objective's routes.

Entry is idiosyncratic; propagation is not

The leave-one-out ablation showed that incidents fail to be reproducible mostly at their first step. Each campaign in this sector seems to arrive through its own door: a drive-by download, a vishing call to a service desk, an exposed enterprise application, a dormant contractor account, an OAuth token in a SaaS integration, a secret in a public repository, an insider offered a million dollars. Internal propagation, by contrast, reuses a small repertoire. A security programme that spends its marginal effort trying to enumerate entry vectors is fighting a long tail; the same effort spent on the propagation repertoire (credential tiering, endpoint management hygiene, the engineering workstation, the ERP–MES coupling, recovery) defends against doors that have not been invented yet. This is an old argument, but the corpus and the ablation give it a concrete, sector-specific measurement.

Sector-level implications

Two corpus incidents, Kojima/Toyota and CDK Global, share a structure no single-enterprise risk model can capture: the failure of one organisation propagated to hundreds or thousands of others through a shared dependency. JLR extends the pattern to a national scale, with more than 5,000 organisations affected [9, 10]. Regulatory frameworks are beginning to recognise vehicle manufacturing as in scope for critical-infrastructure obligations [34, 35], but obligations placed on individual entities do not by themselves address concentration risk in shared platforms. The natural extension of CAPM is a sector-level graph in which OEMs, Tier- n suppliers and shared platforms are vertices and just-in-time coupling is an explicit amplification parameter; the model as specified already treats the supplier interface as a first-class plane, so the extension is mechanical, not conceptual.

Applying the model in a plant

The intended workflow for a practitioner is: (1) replace the reference asset set with the plant’s own inventory, preserving the five planes; (2) mark each edge as present, absent or conditionally present, since the absence of an edge is a security claim and writing it down converts an assumption into an auditable statement; (3) re-elicite p , δ and effort with plant engineers, using purple-team results where available; (4) run the pipeline; (5) read the outputs as a ranked conduit and control agenda expressed in IEC 62443 and NIST CSF terms. The value of the exercise is less in the absolute loss figures, which inherit all the uncertainty of their inputs, than in the relative ordering and, above all, in the disagreements it surfaces between what a plant believes about its segmentation and what its own conduit inventory implies.

Threats to Validity

Construct validity. Edge probabilities are expert-elicited point estimates rather than measured frequencies; no public dataset supports per-technique success rates in automotive OT environments. We mitigate this by publishing every parameter, by reporting perturbation results, and by restricting our claims to those that survive perturbation. The consequence model assumes losses accrue linearly in outage duration, which understates the non-linear effects of missed launch dates and contractual penalties.

Internal validity. The campaign policy is a noisy best-first search under a utility vector. Real actors are less consistent and occasionally more creative; in particular, the displacement effect of section 6 depends on the assumption that an actor rationally re-targets when cheap objectives are removed. Steps are treated as conditionally independent given the actor’s holdings, which ignores correlated failures such as a single credential unlocking several conduits at once; this biases likelihoods downward for identity-centric routes.

Empirical validity. The corpus is a record of what was *reported*, not of what happened. Victims of manufacturing incidents rarely publish forensic detail, so internal propagation is inferred in most records and only the entry vector and the consequence are usually attested; the confidence labels mark which is which, and four records are labelled low or disputed for that reason. Vectors that produce no disclosure obligation and no visible outage are structurally under-represented, which is the direction in which the corpus most likely misleads: quiet espionage and unsuccessful campaigns are close to invisible in it. Statements in this paper about frequency therefore describe the corpus, not the sector. **External validity.** The corpus rests on public reporting, which is biased towards incidents large enough to disturb production or trigger disclosure, and towards Europe, North America and Japan. Silent intrusions, successful defences and incidents at smaller Tier- n suppliers are systematically under-represented, so the model is calibrated on the visible part of the distribution. The reference architecture describes a high-automation vehicle assembly plant; a stamping plant, a battery cell factory or a low-automation facility would require a different instance, although we expect the five-plane structure to transfer.

Comparison validity. The baselines of F7 are our own operationalisations of practitioner heuristics, not published methods, and a proponent of zone-centric prioritisation would reasonably argue that no one ranks paths by depth alone. The comparison should be read as testing the *assumption* those practices encode, not as a benchmark against a specific tool. The corpus is also the evidence that informed the graph’s structure, which flatters CAPM and B2 relative to B3 and B4; the leave-one-out ablation of F2 bounds how much.

Conclusion validity. Monte Carlo estimates use 20,000 campaigns per configuration with fixed seeds; differences of less than roughly 3% in ALE between neighbouring configurations should not be interpreted. The corpus, at 20 incidents, supports descriptive proportions with wide confidence intervals; we therefore report counts alongside percentages throughout.

Ethics. The corpus is built exclusively from public reporting, and the model operates at the level of techniques and conduits, never exploits: no vulnerability details, payloads or procedures that would assist an attacker appear in the paper or in the released artefact. The reference architecture is generic and does not describe any identifiable plant.

Conclusion and Future Work

We set out to model the automotive plant, rather than the vehicle, as critical infrastructure, and to answer a question the vehicle-centric literature does not address: which paths actually reach the assembly line. The answer, on both the empirical record and the model, is that the shortest route to a stopped line runs through business and logistics systems: a supplier’s EDI interface, an Internet-facing enterprise application, an ERP core, an MES. It does not run through a controller. The most likely route to a production stoppage is $11.6\times$ more likely than the most likely route that reaches supervisory control or below; 55% of the corpus incidents caused an availability impact while only 10% are reported to have interacted with equipment below level 3. Detection efficacy is the parameter that matters most, recovery capability is the single most valuable investment class, controls that look worthless in isolation turn out to be the least removable ones in a mature programme, and partial hardening can displace risk from one objective onto a more damaging one.

Measured against the prioritisations a plant uses today, the model places the median observed incident near the top of its list where depth- and segmentation-centric heuristics place it near the bottom; a ranking that ignores containment altogether, however, does as well as the full model, which bounds what the containment term can be claimed to do.

Four extensions follow directly. First, *calibration*: replacing elicited probabilities with measurements from purple-team exercises and plant telemetry, and updating them in a Bayesian fashion as evidence accumulates. Second, *sector-level modelling*: lifting the graph from one plant to a network of OEMs, suppliers and shared platforms with explicit just-in-time coupling, which is the only level at which the Kojima, CDK and JLR class of event can be priced. Third, *live instantiation*: deriving edges from asset-inventory and network-flow data instead of expert elicitation, so that the model tracks a plant as it changes. Fourth, *validation in a testbed*: executing the top-ranked paths against a physical or digital-twin line to measure the parameters this paper had to elicit. The artefact accompanying this paper [11] is structured so that each of these is an extension of the existing pipeline and not a rewrite.

Artefact Availability

The model, the incident corpus with sources, the experiment pipeline, the figures and the test suite are available at <https://github.com/rikosoo/InfraCriticalCar>. The supplementary material lists every parameter of the model with its rationale and supporting evidence. The implementation uses only the Python standard library; `python3experiments/run_all.py` regenerates every table, figure and number reported in this paper, and `pytest` runs the accompanying test suite.

Appendix: Selected Model Parameters

Tables 5 to 7 report the scenario, greedy portfolio and control-necessity results in full. The complete edge list with per-step p , δ , effort, technique, applicable controls and supporting incident evidence is given in `capm/architecture.py` of the artefact, and the control parameters in `capm/controls.py`. The consequence model uses triangular outage distributions with modes of 120 hours for production stoppage and 168 hours for a safety consequence, a loss rate of \$1.05M per hour of stopped production, and fixed response costs with modes of \$25M, \$90M, \$150M, \$40M and \$25M for production stoppage, quality degradation, safety, engineering data theft and personal-data breach respectively. Traversal of the backup infrastructure multiplies sampled outage duration by 1.8, of the endpoint management platform by 1.25 and of the OT domain controller by 1.15.

References

- [1] International Organization for Standardization. ISO/SAE 21434: Road vehicles — cybersecurity engineering. Technical report, ISO, 2021.
- [2] United Nations Economic Commission for Europe. UN regulation no. 155 — uniform provisions concerning the approval of vehicles with regards to cyber security and cyber security management system. Technical report, UNECE, 2021.
- [3] International Electrotechnical Commission. IEC 62443-3-2: Security for industrial automation and control systems — security risk assessment for system design. Technical report, IEC, 2020.
- [4] International Electrotechnical Commission. IEC 62443-3-3: Security for industrial automation and control systems — system security requirements and security levels. Technical report, IEC, 2013.
- [5] Keith Stouffer, Michael Pease, CheeYee Tang, Timothy Zimmerman, Victoria Pillitteri, Suzanne Lightman, Adam Hahn, Stephanie Saravia, Aslam Sherule, and Michael Thompson. Guide to operational technology (OT) security. Technical Report NIST SP 800-82r3, National Institute of Standards and Technology, 2023.
- [6] Theodore J. Williams. The Purdue enterprise reference architecture. *Computers in Industry*, 24(2–3):141–158, 1994.
- [7] Toyota cyberattack: Production to restart in Japan after attack on Kojima Industries. CNN Business, <https://www.cnn.com/2022/03/01/business/toyota-japan-cyberattack-production-restarts-intl-hnk>, 2022. accessed 16 September 2026.
- [8] Toyota halts production across Japan after ransomware attack. Infosecurity Magazine, <https://www.infosecurity-magazine.com/news/toyota-production-japan-ransomware/>, 2022. accessed 16 September 2026.
- [9] Cyber Monitoring Centre. Statement on the Jaguar Land Rover cyber incident. <https://cybermonitoringcentre.com/2025/10/22/cyber-monitoring-centre-statement-on-the-jaguar-land-rovercyber-incident-october-2025/>, 2025. accessed 16 September 2026.
- [10] Jaguar Land Rover attack to cost UK £1.9bn, say cyber monitors. Computer Weekly, <https://www.computerweekly.com/news/366633395/Jaguar-Land-Rover-attack-to-cost-UK-19bn-say-cyber-monitors>, 2025. accessed 16 September 2026.
- [11] Henrique Hoffmann Stefanutti. CAPM: Cyberattack path model for automotive manufacturing — reference implementation and incident corpus. <https://github.com/rikosoo/InfraCriticalCar>, 2026.

- [12] Michael J. Assante and Robert M. Lee. The industrial control system cyber kill chain. Technical report, SANS Institute, 2015.
- [13] Ralph Langner. Stuxnet: Dissecting a cyberwarfare weapon. *IEEE Security & Privacy*, 9(3):49–51, 2011.
- [14] Jill Slay and Michael Miller. Lessons learned from the Maroochy water breach. *Critical Infrastructure Protection, IFIP*, 253:73–82, 2007.
- [15] Defense Use Case. Analysis of the cyber attack on the Ukrainian power grid. Technical report, Electricity Information Sharing and Analysis Center (E-ISAC) and SANS, 2016.
- [16] Kevin E. Hemsley and Ronald E. Fisher. History of industrial control system cyber incidents. Technical Report INL/CON-18-44411, Idaho National Laboratory, 2018.
- [17] Cynthia Phillips and Laura Painton Swiler. A graph-based system for network-vulnerability analysis. In *Proceedings of the 1998 Workshop on New Security Paradigms*, pages 71–79. ACM, 1998.
- [18] Oleg Sheyner, Joshua Haines, Somesh Jha, Richard Lippmann, and Jeannette M. Wing. Automated generation and analysis of attack graphs. In *Proceedings of the IEEE Symposium on Security and Privacy*, pages 273–284, 2002.
- [19] Xinming Ou, Sudhakar Govindavajhala, and Andrew W. Appel. MulVAL: A logic-based network security analyzer. In *Proceedings of the 14th USENIX Security Symposium*, 2005.
- [20] Lingyu Wang, Tania Islam, Tao Long, Anoop Singhal, and Sushil Jajodia. An attack graph-based probabilistic security metric. *Data and Applications Security XXII, LNCS*, 5094:283–296, 2008.
- [21] Barbara Kordy, Ludovic Piètre-Cambacédès, and Patrick Schweitzer. DAG-based attack and defense modeling: Don’t miss the forest for the attack trees. *Computer Science Review*, 13–14:1–38, 2014.
- [22] Harjinder Singh Lallie, Kurt Debattista, and Jay Bal. A review of attack graph and attack tree visual syntax in cyber security. *Computer Science Review*, 35:100219, 2020.
- [23] Kengo Zenitani. Attack graph analysis: An explanatory guide. *Computers & Security*, 126:103081, 2023.
- [24] Eric J. Byres, Matthew Franz, and Darrin Miller. The use of attack trees in assessing vulnerabilities in SCADA systems. *Proceedings of the International Infrastructure Survivability Workshop*, 2004.
- [25] Chee-Wooi Ten, Chen-Ching Liu, and Govindarasu Manimaran. Vulnerability assessment of cybersecurity for SCADA systems. *IEEE Transactions on Power Systems*, 23(4):1836–1846, 2008.
- [26] Adam Hahn and Manimaran Govindarasu. Cyber attack exposure evaluation framework for the smart grid. *IEEE Transactions on Smart Grid*, 2(4):835–843, 2011.
- [27] Siwar Kriaa, Ludovic Piètre-Cambacédès, Marc Bouissou, and Yoran Halgand. A survey of approaches combining safety and security for industrial control systems. *Reliability Engineering & System Safety*, 139:156–178, 2015.
- [28] Yulia Cherdantseva, Pete Burnap, Andrew Blyth, Peter Eden, Kevin Jones, Hugh Soulsby, and Kristan Stoddart. A review of cyber security risk assessment methods for SCADA systems. *Computers & Security*, 56:1–27, 2016.
- [29] Jack Freund and Jack Jones. *Measuring and Managing Information Risk: A FAIR Approach*. Butterworth-Heinemann, 2014.

- [30] Douglas W. Hubbard and Richard Seiersen. *How to Measure Anything in Cybersecurity Risk*. Wiley, 2016.
- [31] Blake E. Strom, Andy Applebaum, Doug P. Miller, Kathryn C. Nickels, Adam G. Pennington, and Cody B. Thomas. MITRE ATT&CK: Design and philosophy. Technical Report MP180360R1, The MITRE Corporation, 2018.
- [32] Otis Alexander, Misha Belisle, and Jacob Steele. MITRE ATT&CK for industrial control systems: Design and philosophy. Technical report, The MITRE Corporation, 2020.
- [33] International Electrotechnical Commission. IEC 62443-2-4: Security program requirements for IACS service providers. Technical report, IEC, 2015.
- [34] European Parliament and Council. Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the union (NIS 2). Official Journal of the European Union L 333/80, 2022.
- [35] Cybersecurity and Infrastructure Security Agency. Critical manufacturing sector. <https://www.cisa.gov/topics/critical-infrastructure-security-and-resilience/critical-infrastructure-sectors/critical-manufacturing-sector>, 2024. accessed 16 September 2026.
- [36] Throwback attack: WannaCry ransomware takes Renault-Nissan plants offline. Control Engineering, <https://www.controleng.com/throwback-attack-wannacry-ransomware-takes-renault-nissan-plants-offline/>, 2022. accessed 16 September 2026.
- [37] European car plants halted by WannaCry ransomware attack. NBC News, <https://www.nbcnews.com/business/autos/european-car-plants-halted-wannacry-ransomware-attack-n759496>, 2017. accessed 16 September 2026.
- [38] Hospital-busting hacker crew may be behind ransomware attack that made Honda halt car factories. The Register, https://www.theregister.com/2020/06/09/honda_ransomware_snake_ekans_malware/, 2020. accessed 16 September 2026.
- [39] Automotive giant DENSO hit by new Pandora ransomware gang. BleepingComputer, <https://www.bleepingcomputer.com/news/security/automotive-giant-denso-hit-by-new-pandora-ransomware-gang/>, 2022. accessed 16 September 2026.
- [40] Bridgestone Americas confirms ransomware attack, LockBit leaks data. BleepingComputer, <https://www.bleepingcomputer.com/news/security/bridgestone-americas-confirms-ransomware-attack-lockbit-leaks-data/>, 2022. accessed 16 September 2026.
- [41] LockBit ransomware claims attack on Continental automotive giant. BleepingComputer, <https://www.bleepingcomputer.com/news/security/lockbit-ransomware-claims-attack-on-continental-automotive-giant/>, 2022. accessed 16 September 2026.
- [42] Elon Musk confirmed Russian’s plans to extort Tesla. BleepingComputer, <https://www.bleepingcomputer.com/news/security/elon-musk-confirmed-russians-plans-to-extort-tesla/>, 2020. accessed 16 September 2026.
- [43] Toyota: Car location data of 2 million customers exposed for ten years. BleepingComputer, <https://www.bleepingcomputer.com/news/security/toyota-car-location-data-of-2-million-customers-exposed-for-ten-years/>, 2023. accessed 16 September 2026.
- [44] Customer data from 800,000 electric cars and owners exposed online. BleepingComputer, <https://www.bleepingcomputer.com/news/security/customer-data-from-800-000-electric-cars-and-owners-exposed-online/>, 2024. accessed 16 September 2026.

- [45] How did the auto dealer outage end? CDK almost certainly paid a \$25 million ransom. CNN Business, <https://edition.cnn.com/2024/07/11/business/cdk-hack-ransom-twenty-five-million-dollars>, 2024. accessed 16 September 2026.
- [46] Stellantis production halted after attack on auto parts giant Yanfeng. BleepingComputer, <https://www.bleepingcomputer.com/news/security/stellantis-production-halted-after-attack-on-auto-parts-giant-yanfeng/>, 2023. accessed 16 September 2026.
- [47] Automaker giant Stellantis confirms data breach after Salesforce hack. BleepingComputer, <https://www.bleepingcomputer.com/news/security/automaker-giant-stellantis-confirms-data-breach-after-salesforce-hack/>, 2025. accessed 16 September 2026.
- [48] Toyota discloses data breach after access key exposed on GitHub. BleepingComputer, <https://www.bleepingcomputer.com/news/security/toyota-discloses-data-breach-after-access-key-exposed-on-github/>, 2022. accessed 16 September 2026.
- [49] MKS Instruments faces \$200 million loss after february ransomware attack. BleepingComputer, <https://www.bleepingcomputer.com/news/security/mks-instruments-faces-200-million-loss-after-february-ransomware-attack/>, 2023. accessed 16 September 2026.
- [50] National Institute of Standards and Technology. The NIST cybersecurity framework (CSF) 2.0. Technical Report NIST CSWP 29, National Institute of Standards and Technology, 2024.

Contact Information

Henrique Hoffmann Stefanutti, Independent Researcher, São Carlos, Brazil. E-mail: henrique407@outlook.com. The model, the incident corpus with its sources, and the experiment pipeline that generates every number in this paper are openly available at <https://github.com/rikosoo/InfraCriticalCar>.

Acknowledgments

Placeholder: acknowledge reviewers, funding and any plant engineers who took part in parameter elicitation. Anonymise any organisation that has not agreed to be named.

Definitions, Acronyms, Abbreviations

ALE Annualised loss expectancy

ATT&CK MITRE Adversarial Tactics, Techniques and Common Knowledge

CAPM Cyberattack path model, the model defined in this paper

CLP/PLC Programmable logic controller

EDI Electronic data interchange

ERP Enterprise resource planning

HMI Human-machine interface

IACS Industrial automation and control system

IDMZ Industrial demilitarised zone

JIT Just-in-time

MES Manufacturing execution system

OEM Original equipment manufacturer

OT Operational technology

SaaS Software as a service

SCADA Supervisory control and data acquisition

SL-T Target security level (IEC 62443)

SR System requirement (IEC 62443-3-3)

Table 2: Control catalogue mapped to IEC 62443-3-3 system requirements and NIST CSF 2.0 subcategories.

ID	Control	IEC 62443-3-3	NIST CSF 2.0
C01	Phishing-resistant MFA for remote and privileged access	SR 1.1; SR 1.2; SR 1.5; SR 1.7	PR.AA-02; PR.AA-03
C02	Conditional access and device-compliance enforcement	SR 1.13; SR 2.6	PR.AA-05
C03	Administrative tiering and privileged access workstations	SR 1.1; SR 2.1; SR 1.11	PR.AA-05; PR.PS-01
C04	Brokered, just-in-time vendor remote access	SR 1.13; SR 2.6; SR 6.1	PR.AA-05; GV.SC-07
C05	Enforced IT/OT segmentation with an industrial DMZ	SR 5.1; SR 5.2; SR 5.3	PR.IR-01
C06	Application allowlisting and removable-media control on OT hosts	SR 2.3; SR 3.2	PR.PS-05
C07	Endpoint detection and 24/7 monitored response	SR 6.2; SR 3.2	DE.CM-01; DE.CM-09; RS.MA-01
C08	Immutable, offline and exercised backups (IT and OT)	SR 7.3; SR 7.4	PR.DS-11; RC.RP-01
C09	Controller change control and program integrity monitoring	SR 3.4; SR 3.8; SR 7.6	PR.PS-01; DE.CM-09
C10	Attack-surface management and expedited patching of exposed services	SR 7.2; SR 3.10	ID.RA-01; PR.PS-02
C11	SaaS and OAuth token governance	SR 1.9; SR 2.1	PR.AA-05; GV.SC-06
C12	Identity lifecycle hygiene and dormant credential revocation	SR 1.3; SR 1.5	PR.AA-01; GV.SC-07
C13	Continuous OT network monitoring and asset inventory	SR 6.2; SR 7.8	ID.AM-01; DE.CM-01
C14	Supplier security assurance and contractual telemetry	SR 1.13; SR 6.1	GV.SC-01; GV.SC-04; GV.SC-08
C15	Service-desk identity proofing and insider-risk programme	SR 1.1; SR 2.10	PR.AA-01; GV.RR-02
C16	Cloud security and data-exposure posture management	SR 4.1; SR 4.3	PR.DS-01; PR.DS-10; ID.RA-01
C17	Operational resilience: buffers, manual fallback and degraded mode	SR 7.1; SR 7.4	RC.RP-01; RC.RP-05; GV.SC-08

Table 3: Ten most likely attack paths to production stoppage in the baseline configuration S_0 . None of them requires reaching Purdue level 1.

#	$L(\pi)$	Steps	Min. Purdue	Path
1	0.0468	3	5	External threat actor → Tier-1 supplier IT estate → EDI / JIT ordering and logistics interface → Production stoppage
2	0.0408	3	4	External threat actor → Internet-facing enterprise application → ERP and production planning core → Production stoppage
3	0.0315	2	4	External threat actor → Dealer management platform → Production stoppage
4	0.0270	3	4	External threat actor → Remote access VPN gateway → ERP and production planning core → Production stoppage
5	0.0109	4	4	External threat actor → Dormant third-party / legacy credentials → Remote access VPN gateway → ERP and production planning core → Production stoppage
6	0.0104	4	3	External threat actor → Tier-1 supplier IT estate → EDI / JIT ordering and logistics interface → Manufacturing execution system → Production stoppage
7	0.0048	5	4	External threat actor → Internet-facing enterprise application → On-premises Active Directory (tier 0) → Privileged access management and domain administration → Endpoint management / software deployment → Production stoppage
8	0.0044	5	4	External threat actor → Dormant third-party / legacy credentials → On-premises Active Directory (tier 0) → Privileged access management and domain administration → Endpoint management / software deployment → Production stoppage
9	0.0040	5	2	External threat actor → Internet-facing enterprise application → On-premises Active Directory (tier 0) → OT domain controller → SCADA / line control server → Production stoppage
10	0.0037	5	2	External threat actor → Dormant third-party / legacy credentials → On-premises Active Directory (tier 0) → OT domain controller → SCADA / line control server → Production stoppage

Table 4: CAPM against baseline prioritisations. Each ranking orders the same 681 modelled paths; the score is the percentile at which the 20 corpus incidents fall within the paths that reach the same consequence (lower is better). p is an exact two-sided Wilcoxon signed-rank test against CAPM on the paired percentiles.

	Ranking	Median pct.	Mean pct.	Top 10%	Top 25%	τ_b	p	r
CAPM	CAPM path likelihood	4.8	6.8	14/20	20/20	n/a	n/a	n/a
B1	Fewest steps	9.5	11.3	11/20	18/20	+0.76	0.010	-0.65
B2	Exploitability only	6.5	7.9	15/20	19/20	+0.78	0.992	+0.02
B3	Deepest OT reach	95.9	76.9	2/20	4/20	-0.08	$\$<10^{-4}\$$	-0.97
B4	Most zones crossed	98.9	96.7	0/20	0/20	-0.64	$\$<10^{-4}\$$	-1.00

Table 5: Campaign outcomes and annualised loss expectancy per control scenario, big-game ransomware profile.

Scenario	$P(\text{impact})$	$P(\text{stop})$	Downtime (h)	ALE (M\$)	Cost idx
S0 baseline	0.0981	0.0770	24.8	47.57	0
S1 identity-first	0.0977	0.0757	24.4	47.00	23
S2 IEC 62443 zones and conduits	0.0973	0.0758	24.4	47.01	25
S3 supply chain and cloud	0.1037	0.1027	33.2	60.09	19
S4 detect and recover	0.1014	0.0549	4.5	16.86	24
S5 full programme	0.0238	0.0047	0.4	3.37	91

Table 6: Greedy cost-effective control portfolio for the big-game ransomware profile.

Step	Control	Name	ALE after (M\$)	Δ /cost
1	C08	Immutable, offline and exercised backups (IT and OT)	29.23	3.67
2	C17	Operational resilience: buffers, manual fallback and degraded mode	17.31	1.70
3	C11	SaaS and OAuth token governance	16.86	0.11
4	C10	Attack-surface management and expedited patching of exposed services	15.70	0.23
5	C14	Supplier security assurance and contractual telemetry	7.41	1.38
6	C02	Conditional access and device-compliance enforcement	5.52	0.47

Table 7: Necessity of each control inside the full programme S_5 : the annualised loss that returns when the control alone is withdrawn.

Control	Name	Δ ALE (M\$)
C11	SaaS and OAuth token governance	12.86
C14	Supplier security assurance and contractual telemetry	11.83
C07	Endpoint detection and 24/7 monitored response	1.57
C16	Cloud security and data-exposure posture management	1.34
C17	Operational resilience: buffers, manual fallback and degraded mode	1.08
C08	Immutable, offline and exercised backups (IT and OT)	0.62
C02	Conditional access and device-compliance enforcement	0.00
C03	Administrative tiering and privileged access workstations	0.00
C04	Brokered, just-in-time vendor remote access	0.00
C06	Application allowlisting and removable-media control on OT hosts	0.00